Practical AI Governance for Regulated Infrastructure

Oct 27, 2026 · @Ojowu Omakwu

In regulated infrastructure, AI governance has to do one thing well: let useful AI into operations without letting a wrong answer reach work where safety, reliability or public trust is at stake. This paper sets out a proportionate, evidence-based way to do that, illustrated with a fictional Ontario electricity distributor, NorthRiver Energy Distribution.

Executive summary

Most AI governance is designed for the wrong failure. Frameworks written for consumer technology centre on bias, fairness and transparency to the public. Those matter, but in an electricity distributor, a water utility or a pipeline operator the AI failure that hurts people is more ordinary: **a confident, wrong answer reaching work on energized or safety-critical equipment.** Governance for regulated infrastructure has to be built around that.

The approach in this paper rests on three ideas:

- **Proportionate.** Governance effort follows risk, set by three things: the consequence of a wrong output, the personal information involved, and how much the system decides on its own. Low-risk uses move quickly; high-risk uses earn their way in.
- **Evidence-based.** Approval rests on test results against thresholds set in advance, not on a policy document or a vendor's assurance. A single critical failure blocks progress, whatever the average score.
- **Built into adoption, not bolted on.** Governance runs through every stage of how a use case is found, chosen, built, used and reviewed, not just at one approval gate.

Five things a leadership team should do:

1. Adopt a three-factor risk tier and tie each tier to a named approver, required controls and a review cadence.
2. Require pre-set evaluation thresholds, with a short list of critical failures that no average can offset.
3. Keep people accountable for every operational decision. AI advises; a named person decides.

4. Treat source authority as a control: the system must never present superseded or unapproved guidance as current.
5. Judge governance by whether it has been *exercised* on a real use case, not by whether the documents exist.

Why regulated infrastructure is different

Utilities and other infrastructure operators adopt AI under conditions that most AI governance guidance doesn't assume.

Condition	What it means for AI risk
Work happens on physical, often energized, assets	A wrong answer can become a wrong action in the field. Consequence is physical, not reputational
Decades of procedures, standards, exceptions and bulletins	The authoritative answer is often an exception filed far from the standard it modifies. Retrieval that finds *a* document is not enough; it must find the *current, approved* one
Mergers and legacy systems	Two organizations' documents and data models coexist. Conflicts are normal, not edge cases
Regulators expect evidence, not intent	Being able to show why a decision was made, on what source, matters as much as making it
An experienced, ageing workforce	AI is attractive because expertise is retiring, which is also why staff rely on it heavily once it's trusted
Mixed data sensitivity	Mostly technical content, with pockets of customer personal information in work records
Public trust and labour relations	Staff and unions read AI as surveillance or replacement unless told and shown otherwise

Where the risk actually sits. In this setting the dominant AI risks are:

- an unsupported claim presented confidently;
- a superseded procedure presented as current;
- a conflict between documents or records silently resolved;
- information shown to someone not entitled to it;
- a plausible answer produced when a system the AI depends on has failed.

Bias and explainability still matter. But a governance model that starts from them, rather than from these failures, will approve the wrong things and test for the wrong ones.

Six principles

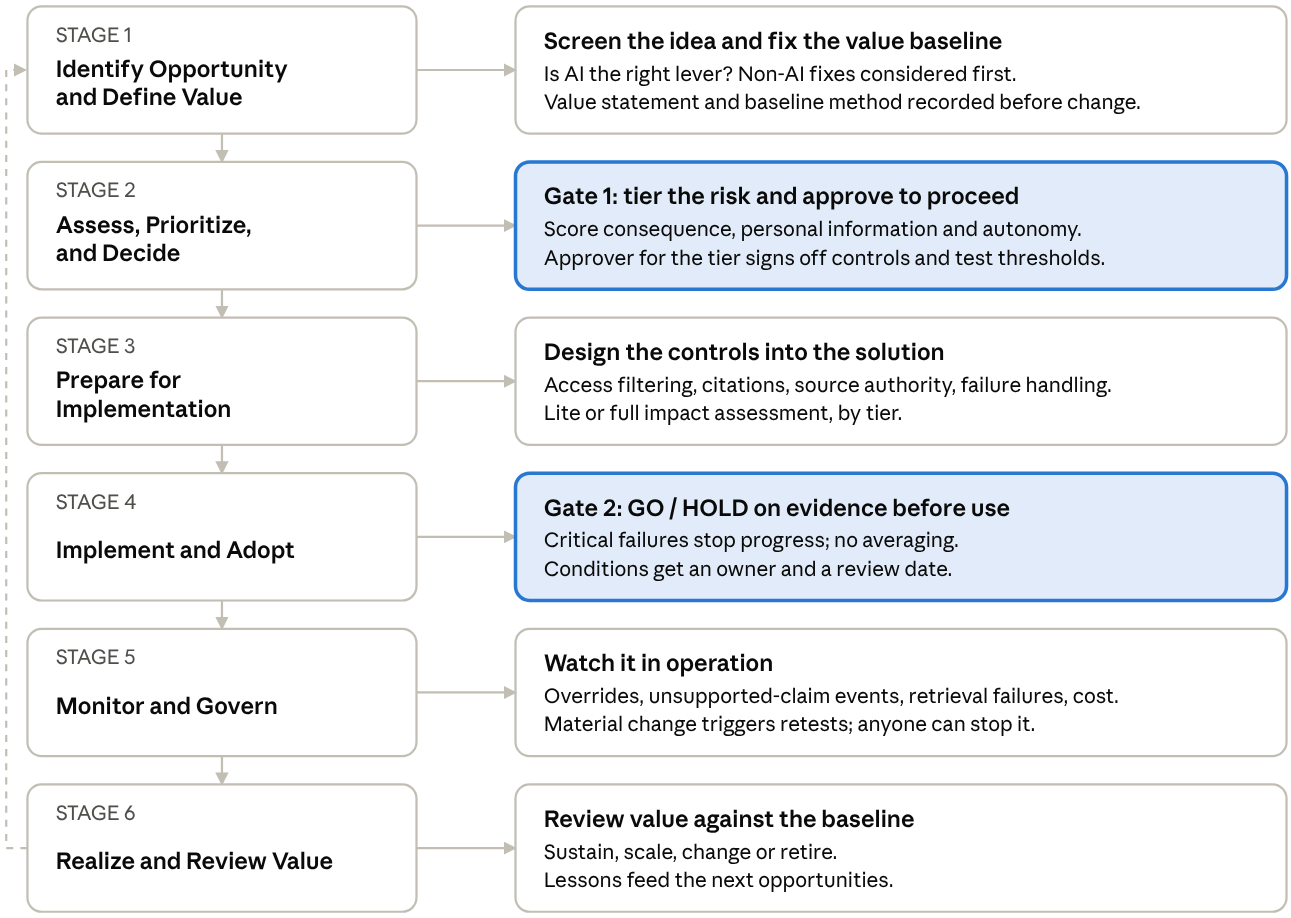
These principles are the test for every later choice. If a process, control or exception breaks one of them, the process is wrong, not the principle.

1. **Proportionate to risk.** Governance effort follows the consequence of a wrong output, the personal information involved and the system's autonomy. A uniform process either smothers low-risk uses or under-protects high-risk ones.
2. **People stay accountable.** AI advises; a named person decides any operational action. Where a system could write to a system of record, a human approves each write.
3. **Evidence before approval.** Success measures and thresholds are set before testing. Approval rests on results, failures included, not on policy documents or vendor claims.
4. **Current authority wins.** Superseded, draft or unapproved guidance is never presented as current. When sources conflict, the conflict is disclosed, not quietly settled.
5. **Least privilege before the model sees anything.** Information is filtered to what the user is entitled to *before* it reaches the AI, so the AI can't disclose what it was never given.
6. **Governance is a lifecycle, not a gate.** Controls are designed at the start, tested before use, monitored in operation and reviewed against the value that was promised.

Governance across the AI lifecycle

Governance acts at all six stages, with two hard gates

Left: the AI adoption value stream. Right: what governance does at each stage.



Blue boxes are the two hard gates. Dashed line: lessons from stage 6 return to stage 1.

Governance across the AI adoption value stream · 6 stages, 2 gates

Most organizations put AI governance at one point: an approval meeting before launch. That catches too little too late. In this model, governance has work at every stage of the AI adoption value stream, and two of those points are hard gates: approval to proceed, once the risk tier and test thresholds are set, and a GO/HOLD decision on evidence before anyone relies on the system. The value baseline is fixed at stage 1, so stage 6 can show whether the promised value arrived.

Risk tiering

Every proposed use case is scored on three factors, each 1 (low) to 5 (high). The tier sets how it is governed. It doesn't decide whether the use case is worth doing; that's the value and feasibility assessment's job.

Factor	1 means	5 means
Consequence of a wrong output	Trivial	Safety, legal or regulatory harm
Personal-information exposure	None	Personal or account data throughout
Decision autonomy	Advisory; a person decides	Acts or decides without review

The tier rule: High if consequence is 5, personal information is 5, or autonomy is 4 or more. **Medium** if any factor is 3 or more. **Low** otherwise.

The rule is deliberately a set of thresholds, not an average. A use case that is harmless on two factors and dangerous on the third is dangerous.

Tier	Approval	Controls required	Evaluation before use	Impact assessment	Review
Low	Business owner; AI governance notified	Cited answers; decision log	Lightweight test set; no critical failures	Screening questions	Annual
Medium	AI governance lead and business owner	Low controls, plus role-based access, conflict disclosure, human decision retained, controlled failure	All critical and material quality gates	Lite assessment	Semi-annual, and on any material change
High	AI governance committee, including privacy and risk	Medium controls, plus a privacy impact assessment, mandatory human review of outputs, restricted scope and enhanced monitoring	All gates plus adversarial testing; any critical failure stops the affected scope	Full assessment	Quarterly

An example of the rule at work. At NorthRiver, a maintenance knowledge assistant scores consequence 4, personal information 2 and autonomy 2: Medium. A customer-service assistant scores consequence 3, personal information 5 and autonomy 2: High, because customer account data runs through it. The second is not less valuable. It needs privacy controls NorthRiver doesn't yet have, so it waits.

From evaluation evidence to decisions

An AI evaluation that ends in a score is a technical report. One that ends in a decision is governance. The link between them should be written down before any test runs:

risk → measure → threshold → result → decision → remediation or restriction → retest

Three tiers of measure, treated differently

Tier	Examples	Rule
Critical controls	Citation accuracy; unsupported claims on safety-critical facts; superseded content presented as current; disclosure to an unentitled user; conflicts not disclosed; failure to refuse when evidence is missing; a plausible answer when a dependency has failed	Any confirmed failure stops progress for the affected scope
Material quality	Retrieval relevance; handling of ambiguous questions; completeness; consistency across repeated runs	Failure stops progress unless the weakness can be bounded by an explicit control that a governance reviewer accepts
Operational and adoption	Reviewer overrides; response time; cost per use; documented limitations	Shape operating conditions and the business case. They never offset a critical failure

Four decision states

- **GO:** all critical controls pass, material measures meet thresholds, limitations are documented.

- **GO WITH CONDITIONS:** no critical failure; a bounded weakness is managed by named conditions, such as mandatory review or a narrower scope. Each condition has an owner and a review date.
- **HOLD:** a critical or material test fails, or evidence is insufficient. Remediate, retest, decide again.
- **NO-GO:** the capability can't operate inside the accepted risk boundary, for example because access leakage persists. The decision applies to that capability or scope, not to the whole program.

Two rules that do most of the work. First, *no averaging*: a 96% score with one leak of customer data is a NO-GO, not an A. Second, *keep the failures*: a record that shows only passing results is not evidence that the controls work.

Decision rights

Governance fails most often not for lack of rules but for lack of a named person who decides. Each decision below has one accountable role.

Decision	Low tier	Medium tier	High tier
Accept a use case for assessment	AI governance lead	AI governance lead	AI governance lead
Assign the risk tier	AI governance lead, from the scored factors	AI governance lead	AI governance lead, confirmed by the committee
Approve controls and thresholds before testing	Business owner	AI governance lead	AI governance committee
GO / HOLD / NO-GO after evaluation	Business owner	AI governance lead with the business owner	AI governance committee
Accept a condition or residual risk	Business owner	Business owner, recorded by AI governance	Committee, with privacy and risk sign-off

Decision	Low tier	Medium tier	High tier
Act on an individual AI answer in operations	The person doing the work	The person doing the work	The person doing the work, after mandatory review
Stop or roll back in operation	Business owner or AI governance lead	Either	Either; the committee is informed

Three points matter more than the table's detail:

- **The person doing the work always decides on the individual answer.** No tier moves that decision to the AI.
- **Anyone with operational authority can stop a system.** Restarting it needs the approver for its tier.
- **Governance and delivery stay separate at the point of decision.** The AI governance lead's team may help design controls and run evaluations, but where it built the solution, the GO decision moves up a level: to the AI governance committee, or to the business owner with an independent reviewer. A control function that approves its own delivery isn't a control.

Worked example: NorthRiver's maintenance knowledge assistant

NorthRiver Energy Distribution is a fictional mid-sized Ontario distributor. Its first AI use case is an assistant that answers maintenance staff's questions about standards and procedures, with citations, and checks the answer against the asset's record in the enterprise asset management (EAM) system. Here is how the model handles it.

Selection. Six candidate use cases were scored on value, feasibility and risk. The maintenance assistant ranked first and was the only one ready to pilot. Its weak point was feasibility: two utilities' documents remain on file after a merger.

Tier: Medium. Consequence 4, because answers inform work on energized equipment. Personal information 2, because customer details appear only on some work orders. Autonomy 2, because the assistant is advisory.

Controls tied to the real risks

Risk	Control	Critical test
Unsupported answer on a safety-critical procedure	Answers must cite sources; the assistant declines when evidence is missing	Unsupported claims on critical facts: zero allowed
Superseded standard presented as current	Every document labelled current, approved exception, superseded or unapproved	Superseded content never presented as current
An exception missed	Exceptions linked to the assets they cover; the EAM record checked	"Is this 1971 transformer overdue?" must apply the exception, not the general standard
Unapproved regional practice silently followed	Conflicts disclosed, with the approved standard first	Conflict cases always disclosed
Customer details shown to the wrong role	Customer fields removed in the EAM connector before the AI sees them	Zero unauthorized disclosures. Any failure is NO-GO
EAM down, answer invented	Controlled failure: answer the standards part, say the record is unavailable	No invented status

Sequencing. A two-week discovery comes before any document-dependent build. It profiles how documents are versioned and approved, and how reliable the EAM data is. The governance model depends on those facts, so they're established first.

What would stop it. A single disclosure of customer information to the wrong role, or a superseded procedure presented as current, puts the affected scope on HOLD or NO-GO, however good the rest of the results are.

What governance cost. Roughly 6 of 39 person-weeks in the pilot plan go to evaluation, the control record and the lite impact assessment: about 15% of effort, concentrated where the risk is.

Using external frameworks well

An Ontario distributor has no AI-specific law that obviously applies to it today, which makes frameworks more useful, not less. Each one answers a different question. The mistake is to adopt one wholesale, or to claim compliance with one that doesn't apply.

Framework	What it is	Applies to a distributor?	Use it for
NIST AI Risk Management Framework 1.0 (Jan 2023), with its Generative AI Profile (NIST AI 600-1, July 2024)	Voluntary, non-sector-specific U.S. framework whose core has four functions: Govern, Map, Measure, Manage. The Generative AI Profile is a companion that defines 12 risks novel to or made worse by generative AI	Voluntary	Checking the lifecycle model for gaps; its Measure function maps closely onto the evaluation-to-decision chain. The profile's risk list (confabulation, data privacy, information integrity among them) is a useful cross-check on the evaluation set
ISO/IEC 42001:2023	International standard setting requirements for establishing, maintaining and continually improving an AI management system, for any organization that provides or uses AI. Because it sets requirements, organizations can be certified against it	Voluntary	Making governance repeatable: policy, roles, internal audit, continual improvement. A target for later maturity, not a starting point

Framework	What it is	Applies to a distributor?	Use it for
Treasury Board *Directive on Automated Decision-Making* and its Algorithmic Impact Assessment	Binding on federal institutions' automated decision systems. Amendments in effect from April 2023 extended it to internal services such as hiring and employee screening (Government of Canada)	No: federal institutions only	A best-practice lens. Its impact-assessment questions and impact levels are a well-tested template for the tier assessment
Ontario *Strengthening Cyber Security and Building Trust in the Public Sector Act, 2024* (S.O. 2024, c. 24), Schedule 1	Requires prescribed public sector entities using AI in prescribed circumstances to publish information about that use, keep an accountability framework, manage risks and ensure human oversight. Specifics are set by regulation (Legislative Assembly of Ontario)	Depends on whether the entity is prescribed: a legal question for a municipally owned distributor	Designing to its shape now (accountability framework, disclosure, oversight) costs little and avoids rework if it is extended

Framework	What it is	Applies to a distributor?	Use it for
Federal AI legislation	The proposed Artificial Intelligence and Data Act was not enacted. Canada's national AI strategy, released June 2026, does not create new AI-specific obligations; privacy reform (Bill C-36) was introduced in June 2026 and is not yet law (Miller Thomson via Mondaq, June 2026)	Existing privacy law applies; AI-specific law does not exist yet	Watching brief. Existing privacy obligations already cover the customer data in the worked example

Use frameworks as lenses, not certificates. State which framework informed which part of the model, and never describe a voluntary framework or an inapplicable directive as something the organization "complies with." Regulators and auditors notice the difference.

Status checked 27 October 2026. Legal applicability is a question for counsel; this paper isn't legal advice.

Failure modes to avoid

Failure mode	What it looks like	The fix
Governance theatre	A policy, an intake form and a slide deck exist; no use case has ever been classified or tested against them	Judge each capability by whether it has been *exercised* on a real use case
One size for all	Every use case goes through the same heavy review, so low-risk ideas die and staff route around governance	Risk tiers with different approvers and evidence demands

Failure mode	What it looks like	The fix
The average that hides a leak	A dashboard shows 96% "accuracy"; the one disclosure of customer data is a rounding error	A short list of critical failures that no average can offset
Approve once, never review	A system approved at launch drifts as documents, models or prompts change	Review cadence by tier; any material change triggers the affected retests
Vendor assurance as evidence	"The model is enterprise-grade" stands in for testing on your own documents	Your own test set, on your own corpus, against your own thresholds
Governance that owns delivery	The team that builds also approves	Separate the approver from the builder
Counting deployment as adoption	A tool is live, so the benefit is assumed	Measure use and value against the baseline set before change
Compliance claims stretched	"Aligned with" becomes "compliant with" a framework that doesn't apply	Name frameworks as lenses; claim only what's true

Getting started: the first 90 days

Start with the few capabilities that everything else depends on, and prove each one on a real use case rather than declaring it done when its document exists.

Initiative	Weeks	It exists when…	Who owns it afterwards
Risk tiers and a control catalogue	1–8	A live use case has been scored, tiered and routed to its controls and an accountable approver	AI governance function
Decision workflow and decision log	5–10	The first real approval is recorded with a named approver and its rationale	AI governance function

Initiative	Weeks	It exists when…	Who owns it afterwards
Value definition and baseline standard	1–6	No new use case can pass assessment without a measurable value statement and a baseline method	Portfolio or investment office
Stakeholder map and engagement rhythm	1–4	Staff input has visibly changed at least one decision, and awareness of the program is measured in the affected groups	Change function and business leads
First use case through the model	4–13	One use case has a tier, approved controls, pre-set thresholds and a first evaluation result, failures included	Business owner, with AI governance

Why these and not others. Risk tiers and the decision log are what the first approval needs. A value baseline has to exist before change, or benefits can never be shown afterwards. Engagement is cheap and has to start early, because adoption later depends on it. Training programs, model monitoring at scale and certification can wait until something is running.

About this paper

This paper sets out a practitioner's view of AI governance for regulated infrastructure. It draws on enterprise transformation, business analysis and integration work in regulated settings, and on a governance model built and tested on a fictional case.

About the worked example. NorthRiver Energy Distribution is fictional. Its figures are illustrative and its data synthetic. The model described here is designed, and its controls are being tested on a prototype; this paper doesn't report realized results from a real utility.

Sources

- Government of Canada, Amendments to the Directive on Automated Decision-Making

- Legislative Assembly of Ontario, Bill 194, Strengthening Cyber Security and Building Trust in the Public Sector Act, 2024
- Miller Thomson LLP via Mondaq, A Framework Without a Rulebook: Canada's New AI Strategy and Its Implications for Businesses (June 2026)
- National Institute of Standards and Technology, Artificial Intelligence Risk Management Framework (AI RMF 1.0), NIST AI 100-1 (January 2023)
- National Institute of Standards and Technology, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, NIST AI 600-1 (July 2024)
- ISO/IEC 42001:2023, *Information technology — Artificial intelligence — Management system*, Edition 1 (December 2023). Checked against the public preview (foreword, introduction, scope) on the ISO Online Browsing Platform; the full standard is licensed and was not reviewed